

Access Control Assessment

NIST SP 800-53 Moderate Baseline — AC Family

PREPARED FOR

Northwind Financial Services Ltd

CONFIDENTIAL

V1.0

REFERENCE

RPT-NW-2026-014

PREPARED BY

CareLock Consulting

ASSESSMENT PERIOD

2026-06-01 to 2026-07-18

ENGAGEMENT

ISMS Readiness Programme

REVIEWED BY

Engagement Principal

FRAMEWORKS

NIST 800-53, ISO 27001

VERSION

v1.0

REPORT DATE

2026-07-24

DISTRIBUTION

Client executive team; internal audit

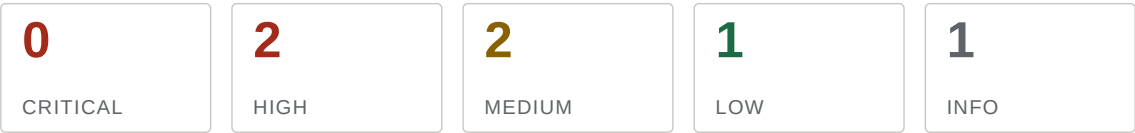
Executive Summary

Northwind has a documented Access Control Policy that is current, approved and mapped to the NIST SP 800-53 Moderate baseline. The policy set is materially sound: of the 17 base controls in the AC family that are in scope, 11 are supported by approved policy text.

The substantive weakness is not in what the policy says but in what is evidenced. Periodic access reviews are mandated at six-monthly intervals and quarterly for privileged accounts, but the organisation could not produce completed review records for two of the four in-scope production systems for the current period. A control that is documented and not evidenced fails an assessment in the same way as a control that was never designed.

A second theme is drift between the documented joiner-mover-leaver process and its operation. Revocation is required within one business day; the sample tested showed a median of four. Neither finding requires new tooling to remediate — both are process and evidence problems, and both are addressable inside the current quarter.

FINDINGS BY SEVERITY



KEY MESSAGES

- The policy set is fit for purpose; the gap is in evidencing operation, not in design.
- Two of four in-scope systems have no completed access review for the current period.
- Leaver revocation is running at a median of four business days against a one-day requirement.
- Six AC-family controls in the Moderate baseline have no approved policy text behind them.

Contents

Executive Summary 2

1 Scope and Objectives 4

2 Approach 4

3 Conclusions 4

4 Findings 5

 4.1 F-01 Periodic access reviews not evidenced for two in-scope systems 5

 4.2 F-02 Leaver revocation exceeds the documented one-business-day requirement 5

 4.3 F-03 Six in-scope AC controls have no approved policy text 6

 4.4 F-04 Shared administrative account in use on the data warehouse 7

 4.5 F-05 Policy statement uses non-testable language in one clause 7

 4.6 F-06 Control mapping is maintained but not reviewed at a defined cadence 7

A Controls Assessed 9

B Severity Definitions 9

Limitations and Basis of Reporting 9

1 Scope and Objectives

This assessment covered the Access Control (AC) family of NIST SP 800-53 Revision 5 at the Moderate baseline, as applied to the four production systems that Northwind has designated as in scope for its ISMS: the core banking platform, the customer portal, the data warehouse and the corporate identity provider.

The objective was to determine, for each in-scope control, whether an approved policy or procedure exists, whether the documented control is operating, and whether operation can be evidenced. Control enhancements were excluded by agreement; at the Moderate baseline they outnumber the base controls and would have materially extended the engagement without changing the conclusions.

2 Approach

The assessment combined documentation review, control owner interviews and sample testing.

Documentation review covered the approved policy set as held in the client's document management system, together with the control mapping maintained in the CareLock control database. Each in-scope control was traced to the policy text asserting it, and the assertion was checked against the control statement rather than accepted at face value.

Interviews were conducted with the Head of Information Security, the IT Operations lead and the four nominated system owners.

Sample testing covered 25 joiner, mover and leaver events drawn from the period, selected to span all four systems and both standard and privileged access. Access review evidence was requested for every in-scope system for the current review period.

3 Conclusions

The design of the access control framework is adequate for the Moderate baseline. The Access Control Policy is approved, within its review cycle, and its statements are testable — they use mandatory language and state measurable frequencies, which is materially better than the sector norm.

Operating effectiveness could not be concluded for two of the four in-scope systems, because the evidence required to reach a conclusion did not exist at the time of testing. This is reported as a finding rather than a qualification: the underlying reviews may well have occurred, but an assessment can only conclude on what is evidenced.

We would expect all findings raised in this report to be closeable within one quarter without capital expenditure.

4 Findings

Ref	Finding	Severity	Control
F-01	Periodic access reviews not evidenced for two in-scope systems	HIGH	AC-2
F-02	Leaver revocation exceeds the documented one-business-day requirement	HIGH	AC-2
F-03	Six in-scope AC controls have no approved policy text	MEDIUM	AC-17
F-04	Shared administrative account in use on the data warehouse	MEDIUM	AC-6
F-05	Policy statement uses non-testable language in one clause	LOW	AC-1
F-06	Control mapping is maintained but not reviewed at a defined cadence	INFORMATIONAL	AC-1

4.1 F-01 Periodic access reviews not evidenced for two in-scope systems

HIGH AC-2 OPEN

OBSERVATION

The Access Control Policy requires user access rights to be formally reviewed at least every six months, with the outcome retained as evidence. For the current review period, completed review records were provided for the core banking platform and the corporate identity provider. No completed records were available for the customer portal or the data warehouse. The system owners for both confirmed that reviews had been performed informally but that no record was retained.

RISK

Access that is no longer appropriate may persist undetected on two systems, one of which holds regulated customer data. In assessment terms the control cannot be concluded as operating, which will result in a qualification if repeated under a certification audit.

RECOMMENDATION

Complete a documented access review for the customer portal and the data warehouse for the current period, and retain the output. Amend the review procedure to require the reviewer to record the population reviewed, the decisions taken and the date, and to file the record in a defined location. Consider generating the review population from the identity provider so the record is reproducible.

MANAGEMENT RESPONSE

Accepted. Reviews for both systems will be completed and evidenced by the end of the quarter, and the procedure will be amended to specify the retention location.

Owner: Head of Information Security Target date: 2026-09-30

4.2 F-02 Leaver revocation exceeds the documented one-business-day requirement

HIGH AC-2 OPEN

OBSERVATION

The policy requires access to be revoked within one business day of a person leaving. Of 25 sampled events, 9 were leavers. Median time to revocation across all systems was four business

days, with a maximum of eleven. The delay was consistently between the Human Resources notification and the service desk ticket being raised, not in the technical revocation itself, which completed within hours once actioned.

RISK

Departed personnel retain access to production systems for a period materially longer than the policy allows. The exposure is highest where the leaver had privileged access, which applied to two of the nine sampled cases.

RECOMMENDATION

Automate the trigger rather than the action: connect the Human Resources leaver event to the service desk so a revocation ticket is raised without manual re-keying. In the interim, introduce a daily reconciliation between the Human Resources leaver report and active accounts, and treat any unrevoked leaver older than one business day as an incident.

MANAGEMENT RESPONSE

Accepted. The HR-to-service-desk integration is already in the IT roadmap and will be brought forward. Daily reconciliation will start immediately as a compensating control.

Owner: IT Operations Lead Target date: 2026-10-31

4.3 F-03 Six in-scope AC controls have no approved policy text

MEDIUM

AC-17

OPEN

OBSERVATION

Of the 17 base AC-family controls in the Moderate baseline, 11 are mapped to approved policy text. Six are not: AC-17 (Remote Access), AC-18 (Wireless Access), AC-19 (Access Control for Mobile Devices), AC-20 (Use of External Systems), AC-21 (Information Sharing) and AC-22 (Publicly Accessible Content). Controls in this group are operating in practice — remote access enforces multi-factor authentication, for example — but no approved document asserts the requirement.

RISK

An operating control with no documented requirement depends on institutional memory. It is not enforceable against a member of staff, it cannot be assessed, and it will regress when the person maintaining it changes role.

RECOMMENDATION

Extend the Access Control Policy, or issue supporting standards, to cover the six unmapped controls. Five of the six are naturally standards rather than policy statements, since they are technology-specific and will change more often than the policy above them.

MANAGEMENT RESPONSE

Accepted in principle. A Remote Access Standard and a Mobile Device Standard will be drafted this quarter; the remaining three will be scheduled for the following quarter.

Owner: Head of Information Security Target date: 2026-12-31

4.4 F-04 Shared administrative account in use on the data warehouse

MEDIUM AC-6 OPEN

OBSERVATION

A shared administrative account is used for scheduled maintenance on the data warehouse. Its use is documented and was approved by the Head of Information Security, which satisfies the policy's exception route. However, the credential has not been rotated since a member of the administration group changed role in March, which the policy requires.

RISK

Actions taken through the account cannot be attributed to an individual, and a former member of the group retains knowledge of a live credential.

RECOMMENDATION

Rotate the credential now, and add credential rotation to the leaver checklist for any individual holding shared-account access. Where the maintenance task supports it, replace the shared account with individually-attributed service principals.

MANAGEMENT RESPONSE

Accepted. Credential rotated on notification of this finding; leaver checklist to be amended.

Owner: IT Operations Lead Target date: 2026-08-29

4.5 F-05 Policy statement uses non-testable language in one clause

LOW AC-1 OPEN

OBSERVATION

One clause of the Access Control Policy states that system owners "are encouraged to" review dormant accounts between formal review cycles. The remainder of the policy uses mandatory language consistently.

RISK

The clause creates no obligation and cannot be tested. It is the kind of wording that reads as a requirement to a reader and as guidance to an assessor.

RECOMMENDATION

Either make the clause mandatory with a stated frequency, or move it into a guideline where non-binding advice belongs.

MANAGEMENT RESPONSE

Accepted. The clause will be made mandatory at the next policy revision.

Owner: Head of Information Security Target date: 2027-02-01

4.6 F-06 Control mapping is maintained but not reviewed at a defined cadence

INFORMATIONAL AC-1 OPEN

OBSERVATION

The mapping between policy text and catalog controls is maintained in the CareLock control database and was accurate at the time of testing. There is no defined cadence for re-validating it against catalog updates.

RISK

The mapping will drift silently as the control catalog is updated, and the coverage reporting derived from it will overstate assurance.

RECOMMENDATION

Re-validate the mapping whenever the control catalog is updated, and at minimum annually alongside the policy review.

MANAGEMENT RESPONSE

Noted. Will be added to the annual policy review checklist.

Owner: Head of Information Security Target date: 2027-02-01

A Controls Assessed

The following NIST SP 800-53 Revision 5 base controls were in scope at the Moderate baseline: AC-1, AC-2, AC-3, AC-4, AC-5, AC-6, AC-7, AC-8, AC-11, AC-12, AC-14, AC-17, AC-18, AC-19, AC-20, AC-21 and AC-22.

Control enhancements were excluded by agreement. Family visibility settings in the control database were used to determine scope, and no families were disabled for this engagement.

B Severity Definitions

Critical — an exposure that is being actively exploited, or that permits unauthenticated access to regulated data. Immediate action required.

High — a control failure that materially increases the likelihood or impact of a security incident, or that would result in a qualification under a certification audit.

Medium — a control weakness that should be remediated in the current planning cycle but that is mitigated by other controls in the interim.

Low — a deficiency with limited practical exposure, typically addressed at the next scheduled revision.

Informational — an observation carrying no present risk, raised because it will become a risk if left unaddressed.

Limitations and Basis of Reporting

This report is prepared for Northwind Financial Services Ltd for the purpose stated in the engagement letter dated 2026-05-18, and is not to be relied upon by any other party without the written consent of CareLock Consulting. The assessment was performed against the scope and period stated and reflects the position at the conclusion of fieldwork on 2026-07-18; it does not address changes made after that date. Conclusions are based on documentation provided, interviews conducted and samples tested, and sample testing provides reasonable rather than absolute assurance. This report does not constitute a certification against any standard, and no opinion is expressed on the financial statements or the internal control over financial reporting of Northwind Financial Services Ltd.